Risk ID	Context Source	Asset / Area	Risk	Likelihood (1-5)	Impact (1-5)	Inherent Score	Inherent Rating	Existing Control	ITGC Evidence Reference	Treatment	Planned Action	Risk Owner	Action Owner	Residual Likelihood (1-5)	Residual Impact (1-5)	Residual Score	Residual Rating	Residual Rationale
R-001	Okta identity dependency	User accounts	Users retain access no longer appropriate for their role	3	4	12	High	Quarterly access reviews	04-User-Access-Management: UAM-T001 (E-001 to E-003)	Reduce	Continue quarterly reviews; extend testing to Q2-Q4	Application Owners	Application Owners	2	4	8	Medium	Quarterly review lowers likelihood. Only Q1 was tested, and impact of retained access is unchanged.
R-002	Okta identity dependency	New user access	Users granted unapproved or excessive access	3	4	12	High	Manager approval required before provisioning	04-User-Access-Management: UAM-T002 (E-004 to E-006)	Reduce	Maintain approval workflow	IT Manager	IT Manager	2	4	8	Medium	Approval before provisioning lowers likelihood. Impact of excessive access is unchanged.
R-003	Employee lifecycle	Terminated user accounts	Terminated employees retain system access	3	5	15	High	Account deactivation within 1-business-day SLA	04-User-Access-Management: UAM-T003 (E-007, E-008)	Reduce	Maintain SLA monitoring	IT Manager	IT Manager	1	5	5	Low	Automated deactivation makes occurrence rare, but a retained account would still have severe consequences.
R-004	Okta dependency; IT and review functions share a reporting line	Privileged accounts	Inappropriate privileged access goes undetected because review lacks independence	3	5	15	High	Quarterly privileged access review	04-User-Access-Management: UAM-T004 (E-009, E-010); SoD observation in 07-Audit-Report	Reduce	Add independent Security/Compliance co-review	IT Manager	Security/ Compliance function (role to be assigned)	2	5	10	Medium	Quarterly review reduces likelihood somewhat. The lack of independent review limits further reduction, and impact remains severe.
R-005	AWS cloud dependency	Production environment	Unauthorized or untested changes cause outage or data issues	2	5	10	Medium	Approval and testing before production deployment	05-Change-Management: CHG-T001 (E-011 to E-014)	Reduce	Maintain change workflow	Engineering Manager	Engineering Manager	1	5	5	Low	Approval and testing make unauthorized or untested changes rare. Outage impact is unchanged.
R-006	AWS cloud dependency	Production database	Backup failures leave gaps in data recovery capability	2	5	10	Medium	Daily backup monitoring and failure investigation	06-Computer-Operations: OPS-T001 (E-015, E-018)	Reduce	Add periodic restore testing (outside current ITGC scope)	Infrastructure Operations	Infrastructure Operations	1	5	5	Low	Monitoring and same-day remediation reduce likelihood. Restore testing is out of scope, so there is no impact credit.
R-007	AWS cloud dependency	Batch processing	Batch failures disrupt operations or produce inaccurate processing	3	3	9	Medium	Batch job monitoring and failure investigation	06-Computer-Operations: OPS-T002 (E-016, E-019)	Reduce	Maintain monitoring	Infrastructure Operations	Infrastructure Operations	2	3	6	Medium	Two March failures occurred and were remediated. Likelihood stays at Unlikely and impact is unchanged.
R-008	Enterprise customer contracts	IT operations	Incidents not identified, tracked, or resolved in time	2	4	8	Medium	Incident logging, tracking, and closure verification	06-Computer-Operations: OPS-T003 (E-017, E-020)	Reduce	Maintain incident process	IT Manager	IT Manager	1	4	4	Low	Tracked closure lowers the chance an incident goes unresolved. Impact is unchanged.
R-009	Enterprise SaaS market and customer expectations	Customer data	Unauthorized access to customer information	2	5	10	Medium	Okta MFA and access controls	MFA enforcement not tested within ITGC scope	Reduce	Add MFA enforcement test in next audit cycle	IT Manager	IT Manager	2	5	10	Medium	MFA exists but was not tested, so no reduction is applied. Residual equals inherent.
R-010	AWS shared responsibility model	Cloud configuration	Misconfiguration exposes data or services	3	4	12	High	None within current ITGC scope	Not tested; control gap	Reduce	Introduce cloud configuration monitoring	Infrastructure Operations	Infrastructure Operations	3	4	12	High	No configuration monitoring control exists within scope. Residual risk equals inherent risk.
R-011	Engineering-driven, cloud-native model	Source code and secrets	Insecure code or hardcoded credentials reach production	2	4	8	Medium	None within current ITGC scope	Not tested; control gap	Reduce	Define secure SDLC controls	Engineering Manager	Engineering Manager	2	4	8	Medium	No secure SDLC control is currently within the ITGC audit scope, so no reduction in likelihood or impact can be justified. Residual risk equals inherent risk pending implementation and testing of secure SDLC controls.
R-012	Third-party apps integrated via Okta SSO	Downstream applications	Compromise of a connected app through the SSO trust relationship	2	3	6	Medium	SSO-managed access lifecycle through Okta	04-User-Access-Management: UAM-T002, UAM-T003 (Okta lifecycle only; partial coverage)	Reduce	Review connected-app inventory annually	IAM Administrator	IAM Administrator	2	3	6	Medium	Current testing provides assurance over the Okta identity lifecycle but does not evaluate security controls within connected third-party SaaS applications. Because these trust relationships remain outside the tested scope, no reduction in residual risk is applied.

Note: ITGC evidence references reflect Q1 2026 interim testing only. Control conclusions are based on the samples tested during the interim period and do not represent full-year operating effectiveness.

Scoring: Inherent Score = Likelihood x Impact; Residual Score = Residual Likelihood x Residual Impact. Rating thresholds (Low 1-5, Medium 6-10, High 11-19, Critical 20-25) per 09-ISO27001-Risk-Assessment/Risk-Assessment-Methodology.md.

Residual rule: tested controls reduce likelihood only; controls that are untested or outside ITGC scope earn no credit (residual equals inherent).

Rating	Inherent	Residual
Critical	0	0
High	5	1
Medium	7	7
Low	0	4
Total	**12**	**12**